

SecurityGroup101

Third-Party Vendor Risk Assessment — Executive Summary

Vendor: Stripe, Inc. · Assessment Date: July 2026 · Prepared by: Maxine Jones, GRC Analyst — mkj00015@mix.wvu.edu

Framework: NIST SP 800-161 Rev. 1 Upd. 1 (Nov. 2024) · NIST SP 800-30 Rev. 1 · PCI DSS v4.0 Req 12.8 · GLBA Safeguards Rule

1. PURPOSE AND SCOPE

This executive summary presents the results of the third-party security risk assessment conducted for Stripe, Inc., SecurityGroup101's payment processing service provider. Stripe is classified as a Tier 1 Critical vendor due to its role in processing payment card data and its direct API integration with SecurityGroup101's production payment systems. This assessment was conducted in accordance with SecurityGroup101's Vendor Risk Management program, aligned to NIST SP 800-161 Rev. 1 Upd. 1 (November 2024) and PCI DSS v4.0 Requirement 12.8 (Third-Party Service Provider Management).

2. VENDOR PROFILE

Vendor Name	Stripe, Inc.	PCI Scope	Yes — PCI DSS Level 1 Certified SP
Headquarters	South San Francisco, CA	PHI Scope	No
Service Type	SaaS — Payment Processing API	PII Scope	Yes — customer billing name and address
Risk Tier	Tier 1 — Critical	Production Access	Yes — API integration with SG101 production systems
Business Owner	VP Finance, SecurityGroup101	Subprocessors	AWS (infrastructure); Google Cloud — both disclosed
Contract Expiry	March 2027	Service Provided	Processes all SG101 customer payment card transactions

3. ASSESSMENT SUMMARY

Assessment Component	Method	Result	Rating
Inherent Risk Questionnaire	16-question IRQ — GRC team	Score: 28/38 (73.7%)	HIGH
CAIQ v4 Self-Assessment	Full 85-question assessment	Score: 83/90 (92.2%)	LOW
SOC 2 Type II Report	Period: Oct 2025 – Mar 2026	No exceptions; unqualified opinion	STRONG
PCI DSS Attestation of Compliance	AoC reviewed — Level 1 Service Provider	Current AoC on file	COMPLIANT
Open Findings Identified	CAIQ gap analysis	2 findings (1 Low, 1 Informational)	LOW IMPACT

4. RISK DETERMINATION

Risk Component	Rating	Basis
Inherent Risk	HIGH	PCI-scoped payment card data, direct production API integration, subprocessors (AWS, Google Cloud), sole-source criticality for payment processing.
Control Effectiveness	STRONG	PCI DSS Level 1 certification, unqualified SOC 2 Type II, FIDO2 MFA on all privileged access, AES-256 at rest / TLS 1.3 in transit, 72-hour breach notification SLA contractually committed.
Residual Risk	MEDIUM-LOW	Inherent risk substantially mitigated by independently validated controls. Two low-impact open findings in remediation — not blocking approval. Per NIST SP 800-30 Rev. 1 Section 3.4.

5. OPEN FINDINGS (Plan of Action and Milestones)

Finding ID	Description	Control	Severity	Due Date	Status
VRM-2026-001	Third-party data sharing register not completed (DSP-09). Stripe committed to Q4 2026 remediation.	DSP-09	Low	Q4 2026	Open
VRM-2026-002	Supply chain risks not yet formalized as discrete items in Stripe's risk register (STA-06). Stripe Q3 2026 internal roadmap item.	STA-06	Informational	Q4 2026	In Progress

6. RECOMMENDATION AND DECISION

Component	Detail
Decision	APPROVED WITH CONDITIONS
Overall Score	CAIQ v4: 92.2% (83/90) · Residual Risk: MEDIUM-LOW
Open Findings	2 findings (1 Low, 1 Informational) — tracked in the Vendor Risk POA with assigned owners and due dates. Not blocking approval.
Approval Conditions	(1) Annual CAIQ v4 reassessment and SOC 2 Type II report review required. (2) Open findings VRM-2026-001 and VRM-2026-002 closed by Q4 2026. (3) Stripe provides 30-day advance written notice of subprocessor changes. (4) Right-to-audit clause maintained in Master Services Agreement.
Monitoring Plan	Quarterly: CISA KEV catalog monitoring. Annually: CAIQ reassessment + SOC 2 Type II + PCI DSS AoC review. Triggered: Out-of-cycle review on any security incident, material change, or subprocessor addition.
Next Review Date	July 2027

7. ANALYST STATEMENT AND APPROVAL SIGNATURES

GRC ANALYST STATEMENT: Based on the assessment evidence reviewed — including the CAIQ v4 self-assessment (92.2% weighted score), current SOC 2 Type II report (unqualified opinion, period ending March 2026), and PCI DSS Level 1 Attestation of Compliance — Stripe, Inc. demonstrates a strong and independently validated security posture. The two open findings are low-impact and do not materially affect SecurityGroup101's risk exposure. This vendor relationship is recommended for continued approval subject to the conditions stated above. Annual reassessment is required to maintain approved status.

Role	Name	Signature	Date
GRC Analyst (Preparer)	Maxine Jones		July 2026
Chief Information Security Officer			
VP Finance (Business Owner)			

Framework: NIST SP 800-161 Rev. 1 Upd. 1 (Nov. 2024) GV.SC-06, SR-9 · NIST SP 800-30 Rev. 1 Section 3.4 · NIST SP 800-53 Rev. 5 CA-5, SA-9, SR-2 · NIST CSF 2.0 ID.RA, GV.SC · PCI DSS v4.0 Req 12.8 (TPSP Management) · GLBA Safeguards Rule 16 CFR Part 314 §314.4(f) · CSA CCM v4.0 / CAIQ v4 · github.com/Mkjones10/securitygroup101-enterprise-grc-program